VERITRUST

Phishing Detection Implementation Handbook

HF-managed production revision

ARCHITECTURE	HF-MANAGED	EVIDENCE-FIRST	PRODUCTION GATES

Authoritative decision. VeriTrust executes no learned production inference in browser code, Vercel functions, platform workers, local runtimes, or VeriTrust-owned model servers. Learned production inference uses Hugging Face-managed infrastructure. The canonical hierarchy is HF-operated hf-inference when the exact model/task and all gates pass; then Hugging Face Inference Endpoint; then private Hugging Face repository plus Hugging Face Inference Endpoint. Third-party Hugging Face Inference Providers are DISABLED_BY_DEFAULT, outside the authoritative production path, and never an automatic fallback.

Status: implementation architecture and research package; no production performance claim. All UNKNOWN values remain explicit.

Prepared from the executable repository, seven historical PDFs, fresh official Hugging Face research, primary competitor sources and C2PA standards.

Contents and control

This is an Implementation Architecture Handbook, not a standalone executable specification. Critical invariants, model identities, deployment classes, evidence semantics, receipt fields, lifecycle states and companion references are generated from validated canonical structured sources; all provider availability is point-in-time and promotion-gated.

NORMATIVE IMPLEMENTATION COMPANIONS: Architecture_Source_of_Truth.yaml; Model_Registry_Proposal.json; HuggingFace_Deployment_Matrix.csv; Implementation_Backlog.csv; Database_Target_Contract.md; Verification_Test_Plans.md; Migration_Roadmap.md.

Cross-document invariants

- HF-managed learned inference only; no normal third-party provider tier.
- Registry resolution precedes dispatch.
- Receipt identifies exact deployment, bundle and ordered learned components.
- raw_output, raw_label, raw_score, normalized_label, normalized_score, calibrated_probability and calibration_version remain distinct.
- Expected-evidence lifecycle uses the canonical 16-state enum: planned, dispatched, running, completed, abstained, not_applicable, unavailable, timed_out, failed, cancelled, privacy_blocked, policy_skipped, insufficient, unsupported, degraded, budget_exceeded.
- Specialist evidence cannot silently substitute or own final policy.
- No original PDF or production source file is overwritten.

1. Executive decision and current paths

Unstructured LLM output and local rules cannot masquerade as a calibrated phishing classifier.

Authoritative decision. VeriTrust executes no learned production inference in browser code, Vercel functions, platform workers, local runtimes, or VeriTrust-owned model servers. Learned production inference uses Hugging Face-managed infrastructure. The canonical hierarchy is HF-operated hf-inference when the exact model/task and all gates pass; then Hugging Face Inference Endpoint; then private Hugging Face repository plus Hugging Face Inference Endpoint. Third-party Hugging Face Inference Providers are DISABLED_BY_DEFAULT, outside the authoritative production path, and never an automatic fallback.

Current MailGuard uses hard-coded generic-label collapse; Cortex can guess a verdict from malformed JSON; direct flows may substitute providers or return local heuristics as model success. Gateway adapters are stricter but behavior is inconsistent.

2. Input modes and canonical artifacts

Mode	Deterministic evidence	Learned input
Plain text	encoding, length, URL/identity extraction	declared text only
Raw RFC 5322	streaming MIME, headers, body parts, attachments	bounded selected text
Trusted receiver event	validated SPF/DKIM/DMARC/ARC and envelope context	minimized message content

3. MIME, authentication and relationship evidence

Parse immutable raw bytes with bounded depth/parts/size/time. Authentication-Results is trusted only from an approved receiver boundary. Build typed sender, reply-to, return-path, display-name, tenant and URL-domain relationships. Authentication failure is evidence; it does not by itself prove phishing.

- Never infer SPF/DKIM/DMARC from untrusted body text.
- Child URLs/images/attachments become their own artifacts and specialist evidence.
- Preserve header/body provenance and reason codes.

4. Learned specialist portfolio

Scientific selection precedes deployment selection. PhishLens is email-specific and smaller; ealvaradob is broader across URL/email/SMS/web and currently mapped to HF-operated hf-inference. Neither is primary until a signed VeriTrust comparison closes role fit, provenance, tokenizer/truncation, robustness, false positives, latency, privacy and license gates.

Role	Candidate	Deployment	Authority
Fast candidate A	PhishLens @ b585a2b	HF Endpoint	promotion-gated evidence
Fast candidate B	ealvaradob @ fa8fb73	HF-operated hf-inference after gates	promotion-gated evidence

Role	Candidate	Deployment	Authority
Mail shadow	cybersectony @ 6724dec	HF-operated serverless shadow	none until labels proven
Multilingual	private mDeBERTa fine-tune	private HF repo + Endpoint	after qualification
Semantic shadow	ModernBERT @ d28c16f	HF Endpoint	shadow
Structured features	private GBDT	private HF custom Endpoint	evidence
Generative explanation	not selected	HF-managed only if separately approved	optional advisory; disabled

5. Cross-engine routing and evidence graph

Extracted URLs route to Link, image attachments to Deepfake when policy/context require it, and relationships remain phishing evidence. The Gateway deduplicates artifacts, preserves parent/child edges and treats child failure as explicit missing evidence.

```
EMAIL ARTIFACT
|- MIME + AUTH + IDENTITY (deterministic)
|- TEXT INTENT (HF)
|- URL CHILDREN -> LINK EVIDENCE
|- IMAGE CHILDREN -> DEEPFAKE EVIDENCE
|- RELATIONSHIPS -> SUFFICIENCY/CORRELATION/POLICY
```

6. Contracts, registry and receipts

Every learned call uses a pre-dispatch registry resolution and a matching receipt. Four generic MailGuard labels remain raw/unknown until an authoritative golden mapping exists; production normalizers reject unknown labels.

Evidence	Fields
Required fields	evidence_id, investigation_id, artifact_id, specialist, scientific_role, registry_resolution_id, deployment_id, model_key, immutable_model_revision, preprocessing_version, input_hash, raw_output, raw_label, raw_score, normalized_label, normalized_score, calibrated_probability, calibration_version, quality, sufficiency, ood_status, status, reason_codes, started_at, completed_at
Lifecycle states (16)	planned, dispatched, running, completed, abstained, not_applicable, unavailable, timed_out, failed, cancelled, privacy_blocked, policy_skipped, insufficient, unsupported, degraded, budget_exceeded
Semantic rule	raw_score, normalized_score, and calibrated_probability are separate nullable fields and never silently substituted.

Receipt	Fields
inference_receipt.v2 fields	receipt_id, registry_resolution_id, deployment_id, deployment_bundle_id, request_id, provider, endpoint_identity, endpoint_deployment_revision, request_sha256, response_sha256, provider_request_id, components, attempt, latency_ms, billed_units, completion_status, received_at
components[] fields	component_role, model_key, repository_id, immutable_revision, artifact_or_container_digest, preprocessing_version, input_schema_version, output_schema_version, execution_order, qualification_status

Receipt	Fields
Compatibility	A valid v1 receipt is exposed as a v2 receipt with one synthetic component derived from its singular repository/model/revision/preprocessing fields; missing historical provenance remains explicit and is never fabricated.

7. Calibration, sufficiency and policy

The model card's accuracy/F1 is not a VeriTrust calibration or production threshold.

Calibrate each role/revision independently on held-out temporal/domain/language slices. Do not add heuristic and model scores. Policy consumes calibrated evidence, authentication observations, relationships, child evidence, quality and missingness. High-impact action requires sufficient evidence or manual review.

8. Benchmark and data governance

- Group by campaign/domain/sender and hold out time to prevent leakage.
- Languages, industries, BEC, credential phishing, QR, reply-chain hijack, benign urgency, newsletters and legitimate authentication failures.
- Record consent/license/provenance and redact personal data in shared artifacts.
- Report PR-AUC, ROC-AUC, class/slice precision-recall, calibration, abstention and operational failure.

9. Endpoint, privacy, failure and cost

Serverless eligibility is exact and point-in-time; it cannot decide the scientific winner. PhishLens targets an HF Endpoint if selected. ealvaradob may use HF-operated hf-inference only after exact-task, quota, latency, privacy, golden-contract and benchmark gates. Minimize message content; never log raw emails/tokens.

Failure	Behavior
HF fully unavailable	High-impact: fail closed or mandatory review. Advisory: degraded/uncertain. Queue only when policy and deadline permit.
One endpoint unavailable	Retry only the same immutable deployment within budget; never silently change model/provider.
Malformed/unknown output	Reject schema/label; persist failed evidence; never guess from text or label digits.
Missing calibration	May display uncalibrated evidence; cannot authorize allow/block.
Timeout/cancel	Persist terminal status and preserve partial evidence; no invented benign value.

10. Tests, deployment and observability

- MIME fuzz/property tests; authentication trust-boundary tests; Unicode/HTML/long-message tests.
- Provider golden labels, malformed/unknown output, timeout/429/5xx and receipt mismatch.
- Observe language, sender/domain slices, authentication patterns, child evidence coverage, calibration/drift, cost and false-positive review outcomes.

- Shadow, tenant canary, controlled promotion and atomic registry rollback.

11. Implementation backlog and done

- VT2-002/003 remove substitution/local-success; VT2-018 qualify fast serverless; VT2-019 resolve MailGuard; VT2-024 multilingual; VT2-026 feature model; VT2-030/031 qualification.
- Done means one phishing evidence contract across direct/Gateway routes, explicit authentication/relationships, HF-only learned calls and review-safe policy.

References and package evidence

Primary sources and immutable model snapshots are listed in Research/Sources/source_ledger.csv and Research/Sources/HuggingFace/. Repository claims are traceable through repository_inventory.csv, source_file_audit.csv, runtime_call_graph.md, current_architecture_map.md and code_claim_ledger.csv.

- Architecture_Source_of_Truth.yaml - canonical invariants, roles, schemas and rollout.
- Model_Registry_Proposal.json - immutable role/deployment proposal.
- HuggingFace_Deployment_Matrix.csv - point-in-time provider and endpoint decisions.
- Technical_Findings_Register.csv / Implementation_Backlog.csv - evidence-backed remediation.
- Database_Target_Contract.md / Database_Migration_Specification.md - logical contract without fabricated SQL.
- Competitor_Analysis.md / Competitor_Matrix.csv - primary-source market design loop.

Authoritative external references

Hugging Face Inference Providers | Hugging Face Inference Endpoints | C2PA Technical Specification. Access dates, exact page URLs, claim summaries and verification status are preserved in the source ledger.

Universal operational controls

Security, privacy, cost, capacity, calibration, observability, incident response and rollback are release gates for every role. No UNKNOWN is replaced with an estimate; unresolved values remain explicit until an evidence-producing test or owner decision closes them.

Final boundary

Hugging Face-managed learned inference is authoritative. No learned production model runs inside the VeriTrust Vercel application or a VeriTrust-owned worker/server; no production weights are required in the VeriTrust deployment repository.